compte les garanties que représentent les certifications, labels et marques destinés à démontrer la conformité au RGPD des opérations de traitement effectuées par les responsables du traitement et les sous-traitants (article 42) ainsi que l'application de règles d'entreprise contraignantes (REC).

Toutes les exigences pertinentes établies dans le RGPD fournissent un cadre général et générique pour la conception et la réalisation d'une AIPD. La mise en œuvre pratique de l'AIPD sera dès lors fonction des exigences du RGPD pouvant être complétées par des indications pratiques plus détaillées. La mise en œuvre d'une AIPD est donc en ce sens adaptable. Cela signifie que même un responsable du traitement opérant sur de petites quantités de données peut concevoir et mettre en œuvre une AIPD adaptée à ses opérations de traitement.

Le considérant 90 du RGPD mentionne un certain nombre d'éléments d'une AIPD qui recouvrent des composantes bien définies de la gestion des risques (par ex. dans la norme ISO 31000[26]). En termes de gestion des risques, une AIPD a pour objectif d'aider à «gérer les risques» pour les droits et libertés des personnes physiques en:

- établissant le contexte: «*compte tenu de la nature, de la portée, du contexte et des finalités du traitement et des sources du risque*»;
- appréciant le risque: «*évaluer la probabilité et la gravité particulières du risque élevé*»;
- traitant le risque: «*atténuer ce risque*» et «*assurer la protection des données à caractère personnel*», et «*démontrer le respect du présent règlement*».

Remarque: l'AIPD au sens du RGPD est un outil de gestion des risques pour les droits des personnes concernées et se place ainsi sous l'angle de leurs droits, comme c'est également le cas dans certains autres domaines tels que la sécurité sociétale, par exemple. À l'inverse, dans d'autres domaines encore (par ex. la sécurité de l'information), la gestion des risques est axée sur l'organisation.

La souplesse offerte par le RGPD permet au responsable du traitement de déterminer la structure et la forme précises de l'AIPD afin qu'elles soient adaptées aux pratiques de travail existantes. Il existe un certain nombre de processus établis au sein de l'UE et dans le monde qui tiennent compte des éléments décrits au considérant 90. Cependant, quelle que soit sa forme, une AIPD se doit d'être une véritable évaluation des risques, permettant au responsable du traitement de prendre des mesures pour y faire face.

Différentes méthodologies (voir l'annexe 1 pour des exemples de méthodologies d'analyse d'impact sur la protection des données et la vie privée) peuvent être utilisées pour faciliter la mise en œuvre des exigences de base énoncées dans le RGPD. Afin de permettre le développement de ces différentes approches, tout en aidant les responsables du traitement à respecter les dispositions du RGPD, des critères communs ont été identifiés (voir l'annexe 2). Ces derniers clarifient les exigences de base du règlement, mais offrent suffisamment de marge de manœuvre pour autoriser différentes formes de mise en œuvre. Ces critères peuvent être utilisés pour démontrer qu'une méthodologie d'AIPD considérée satisfait aux normes établies par le RGPD. **Il appartient au responsable du traitement de choisir une méthodologie, mais cette méthodologie doit satisfaire aux critères visés à l'annexe 2.**

[26] Processus de gestion des risques: communication et consultation, établissement du contexte, appréciation du risque, traitement du risque, suivi et évaluation (voir la section Termes et définitions et la table des matières dans l'aperçu de la norme ISO 31000: https://www.iso.org/obp/ui/#iso:std:iso:31000:ed-1:v1:en).